Sharpflow

ClickUp Health - Technical Validation Overview

Prepared for ClickUp partnership and technical review

Sharpflow Consulting | November 2026 | Version 1.0

1. PURPOSE

ClickUp Health is a read-only workspace assessment. A user connects their own ClickUp workspace through OAuth, selects the workspace, and runs an audit. The product returns a deterministic health score, findings, a drill-down report and a PDF.

This document explains the OAuth flow, the ClickUp data accessed, what the application writes, where data is stored, and how the integration behaves in production.

2. AT A GLANCE

- Product: automated ClickUp workspace health assessment
- Customer access: read-only in behaviour
- Authentication: ClickUp OAuth 2.0
- Customer workspace writes: none
- Separate write path: optional lead capture into Sharpflow's own ClickUp CRM, using a separate Sharpflow token
- AI: Anthropic Claude for the executive summary only
- Hosting: Vercel
- Database: Supabase Postgres
- Background jobs: Inngest
- Report output: web report, drill-downs and branded PDF

3. USER FLOW

- The user clicks Connect ClickUp.
- The user is redirected to ClickUp's OAuth consent screen.
- ClickUp redirects back with an authorization code.
- The app exchanges the code for an access token.
- The token is encrypted and stored server-side.
- The app lists the workspaces the token can read.
- The user selects a workspace, and optionally excludes Spaces.
- A background job reads the workspace structure and task data.
- The deterministic scoring engine calculates the score and findings.
- The report, drill-downs and PDF are generated.
- The user can optionally submit an email to request a follow-up.

4. OAUTH AND PERMISSIONS

- Authorization endpoint: https://app.clickup.com/api
- Token endpoint: https://api.clickup.com/api/v2/oauth/token
- The OAuth flow uses a random state value stored in an HttpOnly cookie to prevent CSRF.

- The access token is encrypted with AES-256-GCM before storage.
- Tokens are never sent to the browser and are never stored in client-side storage.
- The app does not share tokens between customers.
- Each customer authorizes their own workspace.

Important distinction: the current ClickUp OAuth flow does not request granular read-only scopes. Read-only behaviour is enforced by the application: the customer token is only used for GET requests. No create, update or delete call is made with the customer's token.

5. CLICKUP DATA ACCESSED

The customer token is used for the following read-only endpoints:

- GET /user - profile of the connecting user
- GET /team - workspaces available to the token
- GET /team/{teamId}/space - Spaces
- GET /space/{spaceId}/folder - Folders
- GET /space/{spaceId}/list - Lists in a Space
- GET /folder/{folderId}/list - Lists in a Folder
- GET /list/{listId}/field - Custom Fields
- GET /list/{listId}/task - tasks, paginated
- GET /space/{spaceId}/view - saved Views
- GET /team/{teamId}/goal - Goals
- GET /team/{teamId}/custom_item - Custom Task Types
- GET /task/{taskId}/comment - comments sampled for activity metrics
- GET /team/{teamId}/time_entries - time entries for utilisation metrics

The scanner reads workspace structure, task metadata, statuses, Custom Fields, Views, Goals, Custom Task Types, sampled comments and time entries. It does not export the full workspace.

6. READ AND WRITE BEHAVIOUR

Customer workspace

- All customer-workspace requests are GET requests.
- The app never creates, updates or deletes tasks, Lists, Spaces, fields or comments in the customer workspace.
- The app does not subscribe to webhooks in the customer workspace.

Sharpflow lead capture

There is one separate write path, and it does not use the customer's token:

- If a user chooses to submit an email on the report page, the email is stored in Sharpflow's Supabase database.
- If configured, the email can also be sent to Sharpflow's own ClickUp CRM List through a separate Sharpflow-controlled ClickUp token.
- No customer workspace data is written during lead capture.
- Lead capture is optional and is not required to run a report.

7. AI SUMMARY

- Anthropic Claude generates the executive summary.
- The prompt contains the workspace name, overall score, grade, category scores, finding titles and metrics, and strength titles.
- Raw task descriptions, comments, attachments and full task data are not sent to the AI.
- The AI does not calculate or change any score. Scores come from the deterministic engine.

8. DATA STORED

The application stores:

- Encrypted ClickUp OAuth tokens
- Connection metadata: ClickUp user ID, username, email and readable workspace list
- Scan results: score, category scores, findings, coverage and data-quality metadata
- Bounded drill-down samples: list statistics and task sample rows
- Optional lead email submissions

The application does not store full task descriptions, comments or attachments as report content.

9. SECURITY

- Tokens are encrypted at rest with AES-256-GCM.
- The encryption key is held in server-side environment variables.
- Supabase Row Level Security is enabled.
- The Supabase service role key is used only server-side.
- OAuth state is protected with an HttpOnly, same-site cookie.
- The app runs over HTTPS.
- No ClickUp credentials are stored in browser storage.

10. RELIABILITY AND LIMITS

- Requests have a 30-second timeout.
- Pagination is used for tasks, comments and time entries.
- A rate governor adapts to ClickUp's rate-limit headers.
- Requests retry on rate limits and transient failures.
- Very large Lists have a safety page cap; the report records when a scan is truncated or sampled.
- A partial scan is clearly labelled and material missing data fails the scan rather than publishing a misleading score.

11. RETENTION AND DELETION

- Scan results and report data are retained until deleted.
- There is no automatic expiry in the current build.
- Test scans are deleted after validation.
- Workspace connection data can be deleted, and ClickUp tokens can be revoked through ClickUp.
- A configurable retention period can be added for an enterprise or ClickUp-managed deployment.

12. DISTRIBUTION MODEL

- Each customer authorizes their own ClickUp workspace.
- Sharpflow does not use a shared customer token.
- The product can be used directly by a customer, or introduced by ClickUp's sales team and run by Sharpflow for the client.
- No customer workspace write access is required.

13. SUBPROCESSORS

- Vercel - application hosting and deployment
- Supabase - database and authentication storage

- Inngest - background scan orchestration
- Anthropic - AI executive summary
- ClickUp - customer workspace data and OAuth

14. VALIDATION CHECKLIST

- Confirm the OAuth consent screen and redirect URI.
- Confirm read-only behaviour: only GET requests are made with the customer token.
- Confirm the separate lead-capture write path and its token.
- Confirm data stored and retention.
- Confirm no customer workspace writes.
- Confirm AI prompt contains no raw task data.
- Confirm error handling for rate limits, pagination and partial scans.
- Confirm the report and PDF are generated from stored, deterministic results.